

基于等级保护 2.0 标准的网络安全保障体系研究

傅玮 张克晖

中核工程咨询有限公司,北京,西城,100037

摘要:等级保护 2.0 标准(简称“等保 2.0”)体现了国家对于网络安全的高度重视,推行等保 2.0 能有效提高网络安全保障水平。为进一步加强网络安全保障,应依循等保 2.0,不断优化网络安全保障体系。本文简要阐述了等保 2.0 的含义及必要性,并基于等保 2.0 对网络安全保障体系建设提出建议。

关键词:等保 2.0;网络安全;保障体系

网络安全是当下国家发展、行业发展的重中之重。在网络安全建设初期,我国网络安全主要应用的标准为等保 1.0,其技术层面主要从物理安全、网络安全、主机系统安全、数据安全及应用安全五个方面进行测评,等保 1.0 在覆盖范畴上存在一定局限性。目前,各行业的发展以及日常运营都离不开网络信息技术,而网络信息攻击手段以及入侵手段层出不穷,持续威胁着国家以及各行业的网络安全。为减少各类网络安全风险以及网络安全事故发生,需不断强化网络安全保障体系建设,积极落实等保 2.0 的相关要求。

1 等保 2.0 标准概述

1.1 等保 2.0 的含义

等保 2.0 全称为网络安全等级保护 2.0 标准,是我国网络安全领域的基本国策、基本制度,也是等保 1.0 的升级。分级防护标准在 1.0 时代标准的基础上,注重主动防御,从被动防御到安全可信、动态感知和事前事中事后全流程全面审计,实现了对传统信息系统、基础信息系统、云计算、大数据、物联网、移动互联网和工控信息系统等级保护对象的全覆盖。

1.2 等保 2.0 与等保 1.0 的异同点

等保 2.0 与等保 1.0 之间的相同点在于五个级别不变、

规定动作不变以及主体职责不变,不同点主要体现在以下五个方面:

1.2.1 名称变化

等保的标准名称由以前《信息安全技术信息系统安全等级保护基本要求》改为《信息安全技术网络安全等级保护基本要求》,与《信息安全技术网络安全法》保持一致。

1.2.2 定级对象的变化

等保 1.0 主要针对体制内的单位,大部分是一些计算机信息系统;而等保 2.0 保护对象开始向全社会扩展,甚至向云计算、移动互联网、物联网、工业互联网、大数据等新技术领域扩展,不再是以前单纯的计算机信息系统。相比之下,等保 2.0 覆盖范围更广、更全面。

1.2.3 安全要求的变化

等保 1.0 只是信息系统安全等级保护基本要求,而等保 2.0 由一个单独的基本要求演变为“安全通用要求 + 安全扩展要求”两个方面,其中:安全通用要求是必须满足的要求;安全扩展要求是针对云计算、移动互联网、物联网和工业控制系统提出的特殊要求。

1.2.4 控制措施分类结构变化

等保 2.0 调整控制措施的分类结构,充分体现“一个中心 + 三重防护”的思想^[1]。其中,技术部分调整为安全物理环境、安全通信网络、安全区域边界、安全

表 1 等保1.0与等保2.0对比

类别	等保 1.0	等保 2.0
名称变化	《信息安全技术信息系统安全等级保护基本要求》	《信息安全技术网络安全等级保护基本要求》
定级对象变化	信息系统	信息系统、基础信息网络、云计算平台、大数据平台、物联网系统、工业控制系统、采用移动互联技术的网络等
安全要求变化	安全要求	安全通用要求 + 安全扩展要求
控制措施分类结构变化	技术(物理、网络、主机、应用、数据)+ 管理	技术(物理环境、一个中心 + 三重防护)+ 管理
安全体系变化	被动防御系统	事前预防、事中回应以及事后审计的动态安全管理

计算环境、安全管理中心;管理部分调整为安全管理制度、安全管理机构、安全管理人员、安全建设管理、安全运维管理。

1.2.5 安全体系变化

等保2.0从等保1.0的被动防御体系转化为事前预防、事中回应以及事后审计的动态安全管理保障体系。

2 推行等保 2.0 的必要性

2.1 满足当下系统安全要求

网络安全保障技术具备较强的两面性,信息安全技术人员的专业水平越强,其防护水平越强。相对而言,各类攻击的力度也会越强^[2]。在这种环境下,等保2.0更加重视主动防御,以更为全面的防御模式满足当下系统安全要求。

2.2 满足目前法律法规要求

等保2.0依据来源于《中华人民共和国网络安全法》,所有行业在发展以及日常运营中,都应严格遵循该法律法规的要求。因此,推行等保2.0能够满足当下法律法规的要求。

3 基于等保 2.0 的网络和信息安全保障体系优化

3.1 技术层面

目前,网络安全保障体系主要体现在防火墙技术、防病毒技术、入侵检测技术、态势感知、行为审计日志分析等方面^[3]。想要实现网络安全,达到基本的网络安全水平,需要在一个局域网中采用至少3至4种技术,方能实现对信息传输、储存的保护。

3.1.1 防火墙技术

该技术是在信息储存、传输过程中用来抵御各类外来攻击、入侵的第一道屏障。想要提高防火墙技术对信息储存、传输的保护,需加强扫描过滤网络中的进出数据以及读取、写入行为,并将信息读取以及传输过程中的流量进行监测,登记在数据库中,实现对外来攻击以及恶意代码入侵的防控,将正在发生的入侵行为记录于数据库中,优化后续网络安全保障体系的构建,进一步确保网络安全。

3.1.2 防病毒技术

该技术主要通过计算机软件、硬件技术,实现对各类攻击、病毒以及木马的防范,阻止各类恶意软件入侵计算机以及通过网络传播。想要提高该技术的安全保障性能,需不断更新病毒库,跟进了解病毒的发展进程,检测计算机等各类信息设备的木马、病毒,并对其加以记录,进行查杀病毒与修复。

3.1.3 入侵检测技术、入侵防御技术

该技术能够对计算机的行为进行实时监测,一旦出现内部、外部攻击或者误操作,能够第一时间识别攻击来源,并做出防御动作。为提高该技术的防御控制效果,可通过入侵防御技术加强检查网络中传输的数据包,识别信息传输过程中数据包的真正用途,确认该数据包是否具备攻击性,最终决定数据包的去留,进而保障网络安全。

3.1.4 漏洞扫描技术

该技术主要针对硬件设备、软件系统进行扫描,找出网络或系统漏洞,通过打补丁等方式处理漏洞。想要提高该技术的防控效果,可提高漏洞扫描的频率,定期更新漏洞库,对系统进行漏洞扫描,避免漏洞影响系统安全。

3.1.5 行为审计日志分析技术

无论是黑客攻击还是病毒入侵,其痕迹都会被行为审计日志记录。想要进一步提高网络安全保障,可加强对日志记录的分析,挖掘系统中的潜在风险以及威胁,对木马以及漏洞进行清理与修复。

3.2 管理层面

网络安全保障体系离不开切实有效的管理活动,在信息储存以及传输过程中,应明确网络安全管理的重要性,再开展管理活动。

在开展管理活动前,应根据单位实际情况以及网络信息化建设情况,制定相应的安全等级防护规定以及安全防护工作机制。针对网络安全体系配备专业的网络安全领导小组以及安全管理小组,明确网络安全责任人。依据过去发生过的木马入侵、黑客攻击行为制定相应的应急处理方案以及上报制度,确保网络安全管理小组与其他部门相互协调,减少黑客攻击或者木马入侵行为带来的损失。

为进一步强化网络安全保障体系建设,须强化从业人员的网络安全意识,加强《中华人民共和国网络安全法》的宣传普及教育,不断加深从业人员对网络安全重要性的认识,培养各单位网络安全负责人和信息化工作人员的安全责任感和使命感,减少各类人为因素所导致的信息泄露与丢失。

当下各行业的发展以及运营都离不开网络信息技术,网络安全已经成为各行业的重点关注内容。为进一步保障信息读取、传输、储存过程中的安全性,需不断提高从业人员以及安全管理人员的安全防御能力以及防御意识。一方面,各单位应当加强对专业人才的引进,并对现有网络安全管理人员开展专业化培训,打造高水平的技术团队,提升技术人员的网络安全防护意识和技能;另一方面,需要针对普通员工开展网络安全科普培训,加强普通从业人员日常工作中的网络安全防御意识,规避各类信息泄露风险。

积极推动各类安全技术的应用与发展,加强对各类高新网络安全技术的应用,不断更新安全防护软件,定期升级系统、修补系统漏洞。鼓励网络安全管理人员不断学习新技术、新举措,并将其应用于日常管理活动当中。

为尽可能地减少各类网络安全事故,规避各类网络安

全风险,须建立全面、完善的督查以及保障机制,不断更新网络安全技术,并鼓励专业技术人员不断提高安全管理水平。

3.3 人才培养层面

网络安全问题需由专业人才提供支持,各企业在日常运营过程中,应重视其网络安全人才的培养,由专业人才实现对企业内部的网络安全保障体系的优化调整。

人才培养应坚持正确思想,专业技术人员的技术水平越高,对其政治思想觉悟以及价值观的考验越高^[4]。拥有创新能力、高技术水平的专业人员如若受到第三方蛊惑,很容易从企业的保密者变成泄密者,对企业的发展以及网络安全管理极为不利。因此,在网络安全人才的培养方面,应当先为其树立积极正确的价值观以及人生观,加强爱国主义教育,积极开展团建活动,做好法律科普,从而培养专业技术人才的积极价值观。

为了更好地培育青年人才,可采取校企合作的模式,由企业为各高校提供实习机会,培养专业人才;将企业专家引进课堂,提高专业人才的实践能力以及适应能力,加强网络安全管理的创新能力。

4 结语

综上所述,等保 2.0 对等保 1.0 进行了改良及完善,在等保 2.0 下,严格按照“一个中心 + 三重防护”的原则,制定了更高标准的网络安全防护体系^[5],各行业应当加强网络安全保障体系的建设,不断优化更新网络安全技术,做好网络安全防御措施,防止各类黑客攻击以及木马入侵,保护国家以及各行业的信息数据安全。

参考文献:

- [1] 刘伯驹.基于等保2.0网络安全和信息防御体系研究[J].中国安防, 2021, (08):89-91.
- [2] 安述照, 万晓燕.等保2.0制度框架下网络信息安全防护体系构建研究[J].电脑知识与技术, 2022, 18(19):28-30+39.
- [3] 吴小伟.“等保2.0”背景下政府部门网络信息安全防护技术探析[J].江苏科技信息, 2021, 38(32):39-41.
- [4] 童话, 杨浩程, 李怀义.做好等保2.0网络信息安全工作的思考[J].网络安全技术与应用, 2021, (01):167-168.
- [5] 程方, 杨露, 黄紫翎.基于等保2.0标准下的网络安全体系设计与思考[J].现代工业经济和信息化, 2022, 12(12):101-102.